

CONTINUATION

CONTINUATION — HelixCode web-IDE platform

Revision: 4 · **Updated:** 2026-07-01 · **Status:** RELEASED
codeserver-1.0.0-dev-0.0.3 (real-account SSH-key auth) — live-validated (§11.4.169 matrix 23/23 PASS, 0 FAIL), tagged + pushed to all 4 mirrors, GitHub + GitLab releases published; stack LIVE at <https://192.168.0.213:52443>

Read FIRST on any fresh session: this file, then `git fetch --all`, then the auth-pivot spec + AUTH guide + feature ledger below. This is the §12.10 / §11.4.131 standing resumption anchor.

Current phase — **codeserver-1.0.0-dev-0.0.3 RELEASED (real-account SSH-key auth)**

This round pivoted authentication to a **real-account, SSH-key challenge-response** model tying each HelixCode session to the real host user (milosvasic), host-native. Live-validated end-to-end on this host (full edge journey + §11.4.169 matrix **23/23 PASS, 0 FAIL** + Go gate **70 tests -race**), committed (2746e0e), tagged, pushed to all 4 mirrors (no force, §11.4.113), and released on GitHub + GitLab. The stack is LIVE + reachable for operator testing at **<https://192.168.0.213:52443>** — sign the /login challenge with an `~/.ssh/authorized_keys` key (no password). Non-blocking follow-ups: edge-container reboot-persistence; publicly-trusted Let's Encrypt (operator-gated); the loopback:8080 host-firewall recommendation.

- Changelog (this release): `docs/changelogs/codeserver-1.0.0-dev-0.0.3.md`
- Auth pivot spec (authoritative): `docs/superpowers/specs/2026-07-01-auth-pivot-ssh-key.md` (supersedes the live-PAM-login part of `docs/superpowers/specs/2026-07-01-real-account-code-server-design.md`)
- User guide: `docs/guides/AUTH.md`

- Feature ledger + validation verdicts: docs/features/Status.md
- Prior release: docs/changelogs/codeserver-1.0.0-dev-0.0.2.md (TLS / Let's Encrypt + §11.4.169 matrix)

Why the pivot (captured facts, §11.4.6)

This host is ALT Linux with the **tcb** shadow scheme, so a **non-root** service cannot verify passwords via PAM (/etc/tcb/<user>/shadow unreadable by the user; tcb_chkpwd setuid helper permission-denied to non-root ⇒ pam_authenticate returns PAM_AUTH_ERR for every password). A password gate would need root; the operator directive is **no sudo/root** and **all access via SSH keys**. ~/.ssh/authorized_keys is readable and ssh-keygen -Y sign/-Y verify are supported, so SSH-key challenge-response runs fully **as non-root milosvasic**, with **no password and nothing stored**.

Architecture (this release)

```
Browser —HTTPS→ Caddy (TLS edge, CONTAINERIZED rootless Podman;
HTTP/3 + brotli via custom xcaddy)
                    |— forward_auth → helix-auth (host-native
Gin, systemd --user, loopback:8081, NON-root)
                    |— reverse_proxy → code-server (host-native
AS milosvasic, systemd --user,
                                --auth none,
loopback:8080; inherits ~/.ssh, ~/.bashrc, host binaries)
```

- **code-server** — host-native systemd --user, --auth none, loopback:8080.
- **helix-auth** — host-native **Gin** gate, systemd --user, loopback:8081, non-root: SSH-key challenge (GET /login) → verify pasted signature vs authorized_keys (ssh-keygen -Y verify) → __Host-session cookie; GET /auth for forward_auth; **fails closed**.
- **Caddy** — sole containerized component: TLS edge, forward_auth (fail-closed), HTTP/3, encode zstd br gzip, /proxy 403, X-Helix-User strip.
- **Stack directive adopted:** Go + Gin + HTTP/3 (QUIC) + Brotli.

Feature status (§11.4.6 — honest)

The real-account + SSH-key rows in docs/features/Status.md are **In progress / PENDING validation** — no PASS is claimed until captured evidence lands. Testing: Go unit/integration/race (**70 tests, -race, 81.8% cover**) + shell suites tests/types/{e2e,security,stress_chaos,concurrency,load,memory,benchmark,chall

enges, helixqa}_auth.sh + banks tests/banks/helixcode-auth-{challenges, helixqa}.yaml. The live aggregate is the conductor-filled placeholder in the changelog.

Honest boundaries carried into the release

- Editor “jail” is **cosmetic** (Explorer default only; terminal/Open-Folder/ extensions keep full host access by design).
- --auth none on loopback:8080 is a **residual** — host firewall rule for loopback:8080 recommended (all real auth is at the gate/edge).
- code-server pinned **4.117.0** (newest on npm at release time).
- Real public Let’s Encrypt remains **operator-gated** (see docs/guides/TLS.md).

Migration

scripts/install-auth.sh (host-native, **no sudo**) provisions the systemd --user code-server + helix-auth units; deploy/up.sh brings up the Caddy edge. **CODE_SERVER_PASSWORD is retired** → HELIX_AUTH_MODE=sshkey, HELIX_AUTH_ACCOUNT, HELIX_AUTH_AUTHORIZED_KEYS, HELIX_AUTH_PRINCIPAL, PROJECTS_ROOT (no password parameter).

Immediate NEXT (to close the release)

1. Run the live §11.4.169 auth matrix against the freshly-installed host stack; capture evidence under docs/qa/codeserver-1.0.0-dev-0.0.3/.
2. Fill LIVE VALIDATION AGGREGATE in docs/changelogs/codeserver-1.0.0-dev-0.0.3.md with the real PASS/FAIL/SKIP counts (§11.4.6 — never invented).
3. Flip the docs/features/Status.md real-account rows to their verdicts once evidence lands.
4. Full-suite retest (§11.4.40) → tag codeserver-1.0.0-dev-0.0.3 → publish to all upstreams via merge-onto-latest-main (no force-push, §11.4.113).

Binding constraints (every phase)

Port band **52000-52999**; publish only edge ports on 0.0.0.0; **no secrets** (only git-ignored .env); **every gate paired with a §1.1 mutation**; **no --force/--no-verify/bypass**; hardlinked .git backup before destructive ops; **anti-bluff** (PASS needs captured runtime

evidence, no invented numbers); stop + root-cause + full retest on any defect; release prefix codeserver; submodule commits propagate first; docs kept in sync.

Prior state (Phases 1-2, retained)

Phase 1 COMPLETE; Phase 2 core working+verified (Caddy edge + code-server stack on Podman; TLS1.3 edge on 52443, →301 on 52080; \$PROJECTS bind-mounted). Owned submodules (8) at root carry the Constitution inheritance pointer; constitution pinned (see history). Prior release codeserver-1.0.0-dev-0.0.2 shipped Let's Encrypt HTTPS (auto-renew + rotation) + the 14-suite §11.4.169 matrix.